

GenAI Under Attack: Evaluating Enterprise Security Gaps Against Emerging AI Threat Vectors

Ronald Bradford (M.S. Cybersecurity), Michael Goger (M.S. Cybersecurity), Amir Alibali (M.S. Cybersecurity)

Advisor: Charles P. Shelley (MSc., CISSP, CISM)

Foundational Frameworks for GenAI Security Analysis

Three frameworks form the analytical foundation of this paper's threat analysis, selected for their complementary coverage of the GenAI security landscape and their broad adoption across enterprise security practices. The MITRE Adversarial Threat Landscape for AI Systems (MITRE ATLAS) maps tactics and techniques specific to AI systems. The Open Worldwide Application Security Project (OWASP) Top 10 for Large Language Models (LLM) classifies application-layer risks directly relevant to production LLM deployments. Finally, the National Institute of Standards and Technology (NIST) AI Risk Management Framework (AI RMF) provides the organizational governance and structure within which frameworks operate. These three frameworks represent the most widely adopted, actively maintained, and comprehensively scoped foundations for enterprise GenAI security practice. Additional resources including the MIT AI Risk Repository contribute valuable supplementary context and are also referenced.

MITRE ATLAS

The MITRE ATLAS Matrix provides a working knowledge base of adversary tactics, techniques, and real-world case studies specifically for Artificial Intelligence (AI) and Machine Learning (ML) systems. It adapts the established MITRE ATT&CK adversary tactics and techniques matrix which is the standard reference for traditional IT cybersecurity.

The progression and maturity of tactics used in AI attacks is accelerating. First presented in 2021 with 12 tactics and 36 unique techniques (v3.0.0), this framework has now grown to 16 tactics and 97 unique techniques (as at v5.4.0 March 2026). 2025 saw the greatest single year growth of techniques, being 45. While not covered in this paper, the first month of 2026 has added 6 additional techniques further confirming the accelerating pace of AI threat development.

MITRE ATLAS - Technique Maturity Count by Tactic by Year

Maturity Categorization (Feasible / Demonstrated / Realized)



Source: <https://atlas.mitre.org/matrices/ATLAS>

The framework is organized around three analytical layers: tactics that identify adversarial objectives (the Why), techniques that document specific methods of execution (the How), and case studies that ground both in real-world incidents (the Who).

The evolution of MITRE ATLAS reflects the broader trajectory of AI-specific threats, progressing from foundational machine learning attack techniques through ATT&CK alignment, the emergence of LLM-specific exploits, and most recently the full attack surface of autonomous AI agents. The MITRE ATLAS timeline illustrates this progression:

- Feb - May 2021: Core ML-focused tactics and techniques established (reconnaissance, evasion, supply chain, model access)
- Oct - Dec 2021: Expanded with ATT&CK-aligned tactics and sub-techniques
- Oct 2023: Major LLM wave with Prompt Injection, Jailbreak, and LLM Plugin Compromise
- Mar - Apr 2025: RAG/retrieval attacks, LLM obfuscation, prompt crafting, and agentic techniques
- Sep 2025 - Feb 2026: Full AI agent attack surface — agent context poisoning, tool compromise, credential harvesting, lateral movement via agents

MITRE maintains a broader ecosystem of complementary security resources beyond ATLAS and ATT&CK. The Common Weakness Enumeration (CWE), for example, provides a structured catalog of software and hardware weaknesses that architects, designers, and engineers can use to identify and remediate vulnerabilities before deployment — reflecting the well-established principle that security deficiencies are significantly less costly to address at the design stage than after a system is in production.

Open Worldwide Application Security Project (OWASP)

Commencing in May 2023, the lack of comprehensive guidance on securing large language models (LLMs) led a group of security professionals and AI researchers to address this major security challenge emerging in the rapidly evolving generative AI landscape. With businesses accelerating their adoption of LLMs, concerns around adversarial attacks, data leakage, prompt injection, and governance risks grew. At this time structured security frameworks for AI were largely absent. It was in direct response to this gap that OWASP established its LLM security project, publishing the first LLM Top 10 later that year.

OWASP provides many resources building on the foundation of its originally popular Top 10 Risks and Mitigations, now known as the OWASP Top Ten Web Application Security Risks. Reflecting the broader OWASP mission, the project states that "using the OWASP Top 10 is

perhaps the most effective first step towards changing the software development culture within your organization into one that produces more secure code." This principle of accessible, prioritized guidance extends directly to OWASP's LLM-specific work, where the same Top 10 structure is applied to the distinct risk landscape of large language model deployments.

OWASP has developed a growing suite of GenAI-specific resources that extend well beyond the LLM Top 10, providing practical guidance across the full spectrum of organizational roles and deployment contexts.

The OWASP GenAI Security Project organizes its guidance around four audience groups — cybersecurity practitioners, executive leaders (CISOs, CTOs, and CIOs), data scientists, and GenAI developers — recognizing that effective AI security requires coordinated action across technical and organizational roles. Its resources span AI threat intelligence, security governance, secure AI adoption, agentic application security, data security, red teaming and evaluation, and the LLM Top 10, providing each audience group with guidance tailored to their specific responsibilities.

The GenAI Red Teaming Guide, first published in January 2025, provides a practical framework for identifying and evaluating AI vulnerabilities. Notably, it is designed to be accessible to organizations without dedicated security teams, lowering the barrier to structured adversarial testing for companies at earlier stages of AI security maturity.

A Practical Guide for Secure MCP Server Development, released in February 2026, illustrates OWASP's commitment to keeping pace with the evolving deployment landscape. As Model Context Protocol adoption accelerates, this guide provides executives and technical leaders with a structured, practitioner-maintained resource for securing a class of infrastructure that did not exist at enterprise scale only months prior.

NIST AI RMF

First published in January 2023, the NIST AI Risk Management Framework (AI RMF) is built around four core functions: Govern, Map, Measure, and Manage. This framework is designed to help businesses and agencies identify, assess, and manage the risks associated with AI systems throughout their entire lifecycle.

Its four core functions progress logically from organizational readiness to operational response: *Govern* establishes the culture, policies, and accountability structures needed for responsible AI; *Map* helps organizations contextualize their AI use cases and identify relevant risks; *Measure* provides the tools and metrics to analyze and track those risks quantitatively; and *Manage* focuses on prioritizing and treating identified risks with appropriate controls and responses.

The framework is intentionally non-prescriptive and sector-agnostic, meaning it can be adapted to any industry or AI use case including generative AI. NIST released a dedicated profile in late 2024 addressing GenAI-specific concerns including hallucinations, content authenticity, and model misuse. Rather than replacing existing security standards like ISO 27001 or NIST SP 800-53, it is designed to complement them, serving as a governance overlay that brings AI-specific risk thinking into an organization's broader risk management program.

Additional Frameworks and References

The MIT AI Risk Repository, maintained by the MIT AI Risk Initiative, provides a comprehensive and actively curated database of AI risks, incidents, and mitigations that complements the three primary frameworks examined in this paper. Where MITRE ATLAS, OWASP LLM Top 10, and NIST AI RMF provide structured analytical and governance frameworks, the MIT AI Risk Repository offers empirical breadth by aggregating real-world incidents and organizing them through two complementary taxonomies: a Causal Taxonomy that classifies risks by their origin and mechanism, and a Domain Taxonomy that organizes risks by the sector or context in which they manifest. Together these taxonomies provide a cross-referenced view of AI risk that supports and enriches the threat analysis conducted through the primary frameworks.

No single framework provides complete coverage of the GenAI security landscape. MITRE ATLAS identifies the threats, OWASP LLM Top 10 classifies the application-layer risks, and NIST AI RMF provides the governance structure within which both operate. This makes all three necessary components of any credible and comprehensive AI security roadmap.

Citations

OWASP. (2025). *OWASP Top Ten*. Open Worldwide Application Security Project. <https://owasp.org/www-project-top-ten/>

OWASP. (2025). *OWASP Top 10 for large language model applications 2025*. Open Worldwide Application Security Project. <https://genai.owasp.org/llm-top-10/>

OWASP. (n.d.). *OWASP GenAI Security Project*. Open Worldwide Application Security Project. <https://genai.owasp.org/>

OWASP. (2025, January 25). *GenAI red teaming guide*. Open Worldwide Application Security Project. <https://genai.owasp.org/resource/genai-red-teaming-guide/>

OWASP. (2026, February 16). *A practical guide for secure MCP server development*. Open Worldwide Application Security Project. <https://genai.owasp.org/resource/a-practical-guide-for-secure-mcp-server-development/>

National Institute of Standards and Technology. (2023). *AI risk management framework*. U.S. Department of Commerce. <https://www.nist.gov/itl/ai-risk-management-framework>

MIT AI Risk Initiative. (n.d.). *AI risk repository*. Massachusetts Institute of Technology. <https://airisk.mit.edu/>

Cloudsine. (2025, May 8). *Making sense of AI security frameworks: OWASP, MITRE ATLAS, and the NIST RMF*. Cloudsine. <https://www.cloudsine.tech/making-sense-of-ai-security-frameworks-owasp-mitre-atlas-and-the-nist-rmf/>

Red Canary. (2026). *2026 threat detection report: Techniques, trends, & takeaways*. Red Canary. <https://redcanary.com/threat-detection-report/>